



Risk Assessment Frameworks 101: How RAFs Improve Security and Controls

AUGUST 18, 2022 · 7 MINUTE READ

Similarly, you can get a general idea of your corporate risk by evaluating risk events and breaches as they happen. Or, you can proactively use tools and technology to gain a more informed view of your existing—and yet-to-be-known—

 $\wedge$

What Is a Risk Assessment Framework?

Risk assessment frameworks empower your company to [better assess present and future risks by offering data](#) that accurately shows its overall risk level and

3 Primary Risk Assessment Types

tolerance. Your risk assessment framework touches many parts of your business, from informing budgets and planning to helping you create [a security-first](#)

Common Risk Assessment Frameworks

[corporate culture](#). Understanding and creating a risk assessment framework is

more straightforward than it sounds, and it's essential for your company's security.

What Is a Risk Assessment Framework?

A Risk Assessment Framework (RAF) is a strategy to outline, prioritize, and communicate risk-related information related to your greater business infrastructure. This sounds complex, but thankfully, a Risk Assessment Framework's goal is to simplify all of your security information so every team member understands it—whether they have a technical background or not.

RAF is often confused with a similar-sounding concept: [risk management framework](#). This is understandable given the overlapping language and that both processes deal with risk. However, the real difference is found in their scope. Think of risk management as a chair with multiple supporting legs, one of which is risk assessment. While both processes work together with analysis to provide a thorough picture of existing risk, having a sound risk management framework is impossible without an effective RAF. Just like you can't sit on a chair with only two legs, it's vital to establish a robust risk assessment framework as you strengthen your overall risk management process.

PRODUCT SHOWCASE

Watch a brief ERM product demonstration to see Resolver's ERM software in action

[WATCH THE GUIDED TOUR](#)

[TABLE OF CONTENTS](#)



What Is a Risk Assessment Framework?

3 Primary Risk Assessment Types

3 Primary Risk Assessment Types

While there are differences in risk assessment frameworks depending on what area of risk you are solving for—corporate security, GRC, or information security—most reputable risk assessment frameworks fall under one of the three primary types: baseline, issue-based, or continuous. Each assessment type has a unique primary purpose and accomplishes specific goals.

Let's dig into these three types a bit more deeply:

1. Baseline risk assessments



[REQUEST DEMO](#)

prioritize existing risks. Here's a corporate security example to illustrate what a baseline risk assessment might look like. Imagine your brick-and-mortar company lacks an alert on its employee entrance behind the building. A baseline assessment would see that as an unchanging operational flaw and flag it for improvement.

It also examines how this flaw might affect other baseline operations like sales, inventory, and employee productivity. The 10,000-foot-view option of these baseline risk assessments touches almost every function, from people, HR, and tools to processes, materials, environment, and finances.

2. Issue-based risk assessments

While baseline assessments cover problems with regular, consistent processes, issue-based risk assessments take things a step further. They look at the risk created as a domino effect from issues identified in the baseline assessment.

Let's go back to our brick-and-mortar store with the security-free back door. That back door was just used as an entry point for a successful burglary. Now, it's time to run an issue-based assessment and examine how situational changes contributed to this incident. Have shift changes contributed to the door being unlocked for longer than usual during business hours? Is the ordinarily

[TABLE OF CONTENTS](#)



What Is a Risk Assessment Framework?

Answering issue-based questions helps your team implement informed security changes more confidently. It also signals that you're ready to consider adopting the third risk assessment type: continuous risk assessments.

Common Risk Assessment Frameworks

3. Continuous risk assessments

5 Steps to Build Your First Customized Risk Assessment Framework

Unlike the first two assessment types, a continuous risk assessment happens on an ongoing, 24/7 basis. This constant monitoring helps find new risks and better inform any necessary baseline or issue-based risk assessments.

What does this look like in a practical scenario?

A continuous risk assessment should be run all the time—including before and after an incident. Continuing the brick-and-mortar store example, a store manager would likely already have information from a baseline assessment and recognize their employee entrance is a potential vulnerability. They could then take steps to fortify that entrance and reduce security risks, like adding a password keypad or ID scanning or replacing the broken security camera to deter thieves from entering. If an event does occur, they could use the information provided by the issue-based assessment to fix the issues that caused that problem in the first place. Either way, in a continuous assessment, the potential vulnerability will continue to be monitored and assessed to see if fixes prevent future incidents or if a new strategy or protocol needs to be implemented.

The invaluable information from these assessments will mitigate potential risks before they become events and offer risk event-related information to make further mitigation efforts more effective.

Common Risk Assessment Frameworks

There are many different assessment frameworks available. The one you choose will depend on your area of risk management and security, your industry, and the type of risk you need to address. Many respected organizations offer standardized RAFs for specialized industries to ease the assessment process.

TABLE OF CONTENTS



What Is a Risk Assessment Framework?

• **Factor Analysis of Information Risk (FAIR):** [FAIR](#) offers best practices to help executives across all business areas understand and prevent cyber and operational risk. It explains a company's stake in dollars and cents so everyone can understand it, regardless of their role.

3 Primary Risk Assessment Types

Common Risk Assessment Frameworks

• **Committee of Sponsoring Organizations of the Treadway Commission**

5 Steps to Build Your First Customized Risk Assessment Framework

(COSO): [COSO's framework](#) is popular among accounting agencies, finance firms, and publicly-traded companies, thanks to its emphasis on internal controls and how they impact more extensive processes.

• **Information Systems Audit and Control Association (COBIT):** [COBIT](#) was created by the Information Systems Audit and Control Association, or [ISACA](#), and is an ideal framework for businesses that want to improve their IT practices.

• **Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE):** [OCTAVE's risk-based approach](#) is designed for cybersecurity companies largely independent from corporate oversight.

• **Risk Management Guide for Information Technology Systems from the National Institute of Standards and Technology (NIST):** [NIST's guide](#) focuses on highly technical federal information systems and organizations.

• **Threat Agent Risk Assessment (TARA):** [TARA's methodology](#) is well-suited for integrating into and operating with enterprise-level IT and defense-related companies.

5 Steps to Build Your First Customized Risk Assessment Framework

Knowing what you should do to assess risk is pointless without knowing *how* to do it. So, now that you know the assessment type and RAF your company could most benefit from, it's time to build and implement your customized framework to start seeing results.

TABLE OF CONTENTS



1. Pinpoint and evaluate existing risk

Identifying existing and potential risks, or business process mapping, helps your company assess how it should deal with risk-related information when it arises.

3 Primary Risk Assessment Types

Common Risk Assessment Frameworks

5 Steps to Build Your First Customized Risk Assessment Framework

- Outlined risk identification processes should include:
 - Checklists that use your company's common risks to set the standard for future efforts
 - SME and stakeholder interviews to better establish and categorize risk registers
 - Data collection to prove the risks your company faces and to outline a clear path for measurable improvement
 - Scenario analysis to define business-related factors that contribute to higher risk measurements

Once you've established your ideal risk identification process, it's time to engage your workforce. Ask knowledgeable or seasoned employees from various departments what risks or control areas are a significant struggle for them. Use these results to create an [internal risk scale](#) to prioritize your more urgent security needs over less pressing ones.

It may seem obvious, but you won't be able to address them all at once. Once you have a list of your risks, you'll need to prioritize them. Evaluate each one based on how likely it is to happen and how catastrophic it would be if it happened. Something that has a high impact should it happen, but a low chance of taking place isn't as important to fix as something with an increased likelihood of occurring and a significant impact if it does. Plot each risk on a risk matrix with the probability of the event happening along one axis and consequence severity on the other.

What Is a Risk Assessment Framework?

From here, you can create a risk matrix—[we like the bow-tie method](#)—to analyze the likelihood and consequences of potential risks.

3 Primary Risk Assessment Types

Common Risk Assessment Frameworks



5 Steps to Build Your First Customized Risk Assessment Framework

2. Use your assessment results to define a risk management plan

Risk management strategies are what senior management relies on to manage and mitigate operational risks, especially after a breach. And without this clear risk response plan, you might not be able to see other current risks, exposing your company to future violations. So, how do you determine what this plan should look like?

Use the risk matrix created in step one to assess which risks pose the most urgent threat and should be addressed by your risk management strategy first. Then separate those risks into core functions and non-essential ones. Some risks are inevitable. Software bugs up. Machinery needs maintenance. Firewalls can fail. Any business that wants to keep running and growing has to accept an inherent amount of [enterprise risk](#). You must accept core risks to develop and maintain operations, though you should try to mitigate them as much as possible.

Non-essential risks that don't affect core operations could be eliminated entirely. However, some risks (like a company accepting risk beyond its tolerance because its last risk assessment is out-of-date) can be avoided by better processes. Eliminating small, easy-to-address risks lets you focus on the big ones without compromising overall security or worrying about other processes breaking down.

3 Implement your risk management plan using internal security

TABLE OF CONTENTS



What Is a Risk Assessment Framework?

Knowing your existing risks isn't helpful without an action plan to actively mitigate them. The easiest way to start the implementation process is to focus

3 Primary Risk Assessment Types

on the [internal controls](#) that enforce your security standards. Processes can

happen gradually to save time and resources you would otherwise need to

Common Risk Assessment Frameworks

execute an all-in process. For example, tweaking a new hire's job description or

creation is far simpler than asking a long-time employee to alter their workload

or process.

4. Analyze your data and report the results

Data often tells a story, whether we like that story or not. Keep a record of changes to new and existing internal controls during implementation to make it easier to assess the controls as a part of your larger information system and risk management framework. Tracking changes to risk processes also empowers you to determine available data and set objective measurements to analyze results against assessment goals set during the initial evaluation process. To simplify data collection, analysis, and information sharing, we're fans of centralizing your data warehouse in a risk intelligence software solution, like Resolver (naturally).

5. Review and adjust your assessment process

A rigid risk assessment process might help meet your company's current needs for a short period. However, like any business process, it needs adaptability to meet new or unforeseen risks sustainably. Thankfully, when evaluated and analyzed, your already-established [internal controls and data collection processes](#) can provide insights to help risk teams make smart, informed decisions and adjust your assessment as needed.

Build risk assessments for better risk management with Resolver

A well-developed risk assessment framework is incredibly helpful in detailing and communicating risk-related information your technical and non-technical employees can understand. This unity helps your team more thoroughly address existing and potential risks to keep your company safe. However, you can't rely on the same assessment framework to be effective across the board.

What is a Risk Assessment Framework?

[Resolver's Risk Intelligence software](#) offers objective assessments of your risk, with a simple, tailored task list, [AI-enhanced data collection](#), and push-of-a-button reporting capabilities to help you proactively manage every risk, every time. **Take a guided tour through our enterprise risk management software,** **or [contact our product team](#) and request a demo to see it in action.**

5 Steps to Build Your First Customized Risk Assessment Framework

Discover Resolver's Software

Incident Management Software

Protect your organization and prove your security team's value with Resolver's

TABLE OF CONTENTS



What Is a Risk Assessment Framework? Increase operational efficiency, data capture, and generate actionable insights, so you can stop chasing incidents and start getting ahead of them.

3 Primary Risk Assessment Types

Common Risk Assessment Frameworks

5 Steps to Build Your First Customized Risk Assessment Framework

[LEARN MORE](#)

Enterprise Risk Management Software

Provide your organization's board and senior leaders a top-down, strategic perspective of risks on the horizon. Manage risk holistically and proactively to increase the likelihood your business will achieve its core objectives.

[LEARN MORE](#)

Regulatory Compliance

Save time by monitoring all regulatory compliance activities, providing insights into key risk areas, and then focusing resources on addressing regulatory concerns.

What Is a Risk Assessment Framework?[LEARN MORE](#)

3 Primary Risk Assessment Types

Common Risk Assessment Frameworks

5 Steps to Build Your First Customized Risk Assessment Framework

Request a demo

First Name *

Last Name *

Business Email *

Business Phone *

Job Title *

Company *

Why are you looking for software? (Optional)

- ☐ I agree to receive promotional emails from Resolver about events, products, and services. I understand I can unsubscribe from these communications at any time.

TABLE OF CONTENTS



What Is a Risk Assessment Framework?

REQUEST A DEMO

3 Primary Risk Assessment Types

Common Risk Assessment Frameworks

5 Steps to Build Your First Customized Risk Assessment Framework

Sign up for our newsletter

Business Email

SUBSCRIBE

By subscribing you agree to our [privacy statement](#).

PRODUCTS

RESOURCES

COMPANY



© 2025 Resolver Inc. All rights reserved.

[Legal](#) [Privacy Policy](#) [Terms of Service](#) [Accessibility](#)

[Crisp Privacy Policy](#) [Crisp Modern Slavery Statement](#) [Crisp Supplier Code of Conduct](#)

TABLE OF CONTENTS

